

A Zero Trust Architecture for Critical Operational Technology Systems

Meng Wee Song
Naval Postgraduate School
song_meng_wee@hotmail.com

Thuy D. Nguyen
Naval Postgraduate School
tdnguyen@nps.edu

Cynthia E. Irvine
Naval Postgraduate School
irvine@nps.edu

Abstract

Evolving business demands increasingly expose modern operational technology (OT) systems to external networks. Their vulnerability to contemporary cybersecurity threats due to legacy software and hardware requires proactive measures. While the Zero Trust (ZT) paradigm has been embraced for IT systems, its use in OT systems is largely uncharted. We present a ZT architectural model to modernize and secure critical OT systems. Using a water treatment OT system, we evaluated the ZT-OT architecture against real-world remote-access and bring-your-own-device (BYOD) use cases. Our results show the ZT-OT architecture can help mitigate vulnerabilities associated with threats in specific cases and we identified limitations concerning legacy components and normal operation. Our approach offers insights into the potential and challenges of ZT in protecting OT systems.

Keywords: zero trust, operational technology, industrial control systems, remote access, bring-your-own-device (BYOD)

1. Introduction

Industrial control systems (ICS) control processes in critical sectors such as water, electric power, and transportation. ICS are a subset of operational technology (OT) systems, which can operate for decades before needing replacement and prioritize reliability and robustness over flexibility, usability, and cybersecurity (National Institute of Standards and Technology, 2023). Many OT systems have depended on physical obscurity and network isolation for protection against cyberattacks.

Today, both centralized monitoring of satellite OT sites and vendors' remote maintenance of proprietary components can result in cost savings. Connecting legacy systems to external networks is inherently dangerous, yet many OT systems have limited computing resources or network bandwidth and only deploy network segmentation as protection. Furthermore, some organizations permit use of personal devices for business purposes, a practice known as *bring*

your own device (BYOD). Use of such devices increases the risk of accidental or intentional insider attacks, as they can bypass logical and physical protection.

The Zero Trust (ZT) paradigm is based on the notion that trust is never granted implicitly but must be continually verified (National Institute of Standards and Technology, 2020). Hence, by default, devices are not trusted, even if they were previously verified. All access requests must be validated before being granted and all accesses granted must meet the principle of least privilege and implement the models of *just in time access* (JITA) and *just enough access* (JEA) (Shore et al., 2021). In 2022, the U.S. federal government specified a Zero Trust architecture (ZTA) strategy for its agencies. The ZTA approach protects IT systems through strong identity verification, continuous device fingerprinting, and strict enforcement of access controls (Department of Defense, 2022). Different approaches can be used to implement a ZTA, including network micro-segmentation (Basta et al., 2022) and dynamic access policy enforcement (Colombo et al., 2021). However, the feasibility and benefits of applying ZT to OT systems have not been adequately addressed. Although the NIST SP 800-82r3 provides guidance and recommendations for applying ZT to OT systems, its guidance is not detailed (National Institute of Standards and Technology, 2023). To address this, we provide 1) a threat model to understand the risks associated with both remote connectivity (telework) and BYOD for both local and remote accesses in an OT system, 2) a zero-trust OT (ZT-OT) system architecture implementing the ZT tenets to protect a water treatment OT system, and 3) a security analysis of the ZT-OT design using three use cases to determine the effect of ZT on day-to-day water treatment operations.

In this paper, Section 2 provides background on OT systems, ZT, and the water treatment process. The ZT-OT architecture and our analysis of the ZT-OT design using a hypothetical water treatment system are described in Sections 3 and 4, respectively. A discussion of ZT on OT systems and conclusion are in Section 5.

2. Background

The Purdue Security Model consists of six levels, ranging from the physical processes at Level 0 to the enterprise network at Level 4 or 5 (David, 2019). For security controls, the model effectively provides network segmentation and for operational controls, it allows upper layers to add features while allowing lower layers to function independently. Government regulations and guidelines for OT cybersecurity include NIST SP800-82r3 (National Institute of Standards and Technology, 2023) and Singapore's Cybersecurity Agency (CSA) cybersecurity code of practice (CCOP) (Cyber Security Agency of Singapore, 2022). Sector-specific guidelines from the American Water Works Association, the public utilities board of Singapore, and the Australian energy sector provide more granular policies addressing each sector's unique aspects. Private entities have provided or extended their technical frameworks or guidelines to include ICS-specific material. Examples include the extension of the MITRE ATT&CK framework (The MITRE Corporation, n. d.) and the International Electrotechnical Commission (IEC) 62443 standards (International Society of Automation, n. d.).

2.1. OT-related cyber incidents

High-profile OT attacks include STUXNET (Falliere et al., 2011), the Colonial Pipeline incident (Department of Energy n. d.), the Oldmar, Florida water treatment facility compromise (Cybersecurity and Infrastructure Security Agency, 2021; U.S. Senate Republican Policy Committee, 2022), INDUSTROYER (Cherepanov, 2017); and the Maroochy sewage spill (Slay & Miller, 2007). In 2023 and 2024 numerous attacks attributed to Iranian, Russian, and Chinese groups, some described as state-sponsored, were conducted on water treatment plants (Levy, 2024; Bajak, 2023; Miller, 2024). These highlight the threat to a critical infrastructure sector upon which life itself depends.

2.2. Prior work

(Boumhaout et al., 2022) analyzed the potential of using ZTA in critical infrastructure to secure every individual connection instead of just securing networks. Their analysis considered a legacy system, third party vendors and industrial Internet of Things components within the network. They noted that the perimeter defense approach based on the Purdue model can be breached repeatedly. We agree that legacy systems are a major issue and that ZT can be applied to provide a more proactive approach to cybersecurity. Nevertheless, our work explores using ZT to enable additional

functionality such as remote connection and BYOD, in addition to securing OT systems.

(Federici et al., 2023) analyzed the implementation of ZTA to secure remote access for maintenance within a software defined industrial Internet of Things infrastructure consisting of both legacy and modern edge devices. They suggested using distributed policy decision points (National Institute of Standards and Technology, 2020) for edge and network resources due to the difference in their criticality. For future work, they indicated possible development of two-layer models that yield multiple authorizations layers to address different levels of granularity. This approach aligns with our work as we are attempting to secure a system with varying levels of criticality. However, their work did not address BYOD-related threats, as we do.

(Teerakanok et al., 2021) analyzed challenges such as interoperability, proprietary data formats, user disruption and unmanaged devices when migrating legacy architectures to ZTA. They also discussed ZTA implementation challenges, such as lack of standardization, vendor lock-in, and approaches for migration to ZTA. Although they mentioned challenges of handling unmanaged devices, a major problem when considering BYOD, they did not address the challenges of enabling remote access in legacy OT networks.

3. Zero Trust for a water treatment plant

A water treatment plant (WTP) ensures a supply of clean water to its service area. A typical WTP is an IT-OT integrated network to allow centralized monitoring. The Singapore University of Technology and Design's Secure Water Treatment (SWaT) testbed simulates the IT and OT systems of a water treatment facility implementing the six-step water treatment process required to make water potable (Singapore University of Technology and Design, n. d.). We used the SWaT testbed to model the ZT-OT design.

3.1. Concept of operations

The system architecture of the WTP we used for this work is based on the SWaT architecture (Singapore University of Technology and Design, n. d.), which combines legacy OT with modern IT systems. In the pre-ZT configuration, neither BYOD nor teleworking are allowed; all operations must be conducted on premises. The high-level objective of our ZT-OT design is to support both BYOD and telework.

For remote connectivity, the OT system must allow secure remote connections. This enables teleworking, remote maintenance, and secure centralized monitoring of various satellite OT sites. Here, a remote connection is defined as a connection that traverses external

networks such as a leased line or the Internet. For use of personal devices, the OT system must allow personal devices to operate locally and remotely. In addition to personal use, these devices can be used for WTP business and operations. Personal devices must be authorized prior to business use. These devices include handphones, tablets and laptops of employees and external contractors. Wearable devices are outside the scope of the water treatment plant scenario. Table 1 shows both IT and OT user roles relevant to this work.

Table 1. OT user description.

Role	Responsibility
Plant IT Manager	Manages the IT infrastructure and processes in the water plant and is responsible for all company-furnished equipment (CFE) issued to company personnel, including OT personnel.
OT Manager	Is responsible for ensuring water quality and flow of the WTP as well as managing all OT assets including sensors, actuators, PLCs, SCADA server, SCADA workstations, etc.
OT Operator	Ensures daily operation of the OT system and reports to the OT Manager. The role has access to the OT systems but requires explicit approval from the OT Manager to perform privileged operations.
Plant Technician	Performs maintenance on hardware, such as sensors and actuators, in the WTP. The role has no network access to OT or IT systems.
External vendor	Is contracted by the plant operator to build the OT system and provide maintenance services.

3.2. Threat model

Our threat modelling involves two steps: 1) defining the functional requirements for remote access and BYOD and 2) assessing the potential threats and the potential impact of those threats to the WTP.

The functional requirements for remote access were based on guidance from the U.S. Department of Homeland Security and UK Centre for the Protection of National Infrastructure (Centre for the Protection of National Infrastructure, 2010). We crafted our requirements based on the BYOD guidance by the United Kingdom's National Cyber Security Centre (National Cyber Security Centre, n. d.):

- Employees shall be permitted to perform business operations from their personal devices with explicit approval.
- Personal devices shall be allowed for read operation on the OT network. Write operation shall not be allowed.
- Personal devices shall be enrolled prior to accessing the company network.
- Personal device attributes and activity shall be monitored when accessing the OT network.

We used the MITRE ATT&CK framework for ICS systems (The MITRE Corporation, n. d.) to identify and

assess threats associated with remote access and BYOD. Both types of threats can be mapped to the Initial Access category. For remote access, the common threats are exploitation of public-facing applications, and exploitation of on-prem and external remote services (The MITRE Corporation, n. d.). Enabling remote services in OT networks requires additional systems, such as a VPN server, that could potentially be exploited by adversaries. Moreover, enabling remote services also exposes the OT network itself to external threats. For BYOD, the main threats are replication through removable media, wireless compromise, and Internet accessibility of the device (The MITRE Corporation, n. d.). The overarching threat is that personal devices may potentially be used to transfer malware into the OT network or may act as a conduit for attackers to compromise the OT network.

In both cases, the OT network is exposed to either external networks or external devices both of which can function as an entry vehicle into the OT network. While other categories such as evasion techniques and lateral movement are of concern, they are downstream effects after the malicious actor has gained access to the OT network (The MITRE Corporation, n. d.). Compromised access to the OT network could result in disruption to WTP operations, improper dosing of chemicals in the water, or causing water spills.

3.3. Assumptions, policy, requirements

Our design was based on four assumptions: 1) all physical security policies will be enforced; 2) the OT system includes legacy components that cannot be updated, patched, replaced, or removed; 3) no cloud service is connected to the OT network; and 4) the WTP will be based in Singapore and regulated by the CCOP.

The WTP cybersecurity policy has three rules: 1) the IT Manager, OT Manager, and OT Operator shall only have access to network components needed to complete their tasks and, for certain actions that affect the water treatment process, a series of authorizations shall be required; 2) the system shall support both local and remote personnel; and 3) access to the OT system shall only be permitted to personnel with enterprise-issued devices or enterprise-installed agents.

The WTP must meet the security requirements specified in the CCOP with the additional requirements of BYOD and remote access that adhere to requirements in Section 5.7 (remote connection), Section 5.10 (patching), Section 5.11 (portable computing devices), Section 6.1 (logging), and Section 6.2 (monitoring and detection) (Cyber Security Agency of Singapore, 2022). These apply to all personal and company-furnished equipment (CFE) devices connected to the network.

4. ZT-OT design

Our analysis of the ZT paradigm indicated that it is applicable to the remote access and BYOD requirements of the WTP. To enable ZT, the following components are required (National Institute of Standards and Technology, 2020; National Institute of Standards and Technology, 2022): policy enforcement point (PEP), policy decision point (PDP), and policy information point (PIP).

The PEP restricts access to network zones and can be implemented by a firewall or a separate component. Within a network zone, all requests must be routed to the PEP for verification. The PEP then routes the request to the PDP, which uses information from the PIP and a trust algorithm to make access decisions. The PIP provides the information it collects from the following systems to the PDP: identity, credentials and account management, intrusion detection system, user and endpoint behavior analytics, multifactor authentication, and unified endpoint management. This information parameterizes the trust algorithm used by the PDP to determine a subject's risk profile. NIST SP800-207 defines the terms subject as a combination of user, application, services, and devices (National Institute of Standards and Technology, 2020).

A software agent installed on each device communicates with the PEP and provides telemetry about the device such as IP address, port information, or other security artifacts for verification (National Institute of Standards and Technology, 2020). We separated our network into three enclaves based on the network criticality: IT network zone, OT network zone, and trusted zone, which contains legacy devices. We use the concept of *policy enforcement* (PE) levels to distinguish varying security requirements across different networks for fine-grained security control (Federici et al., 2023). This is required due to differences in the criticality between IT and OT networks. Within IT and OT networks, different network segments may have different PE levels.

Although NIST SP800-207 states that software agents are compulsory (National Institute of Standards and Technology, 2020), their use is optional in our design. This provides users flexibility when registering personal devices for business use. We made two changes to the NIST recommendations regarding authorized software agents: (1) company-controlled software agents will be installed on personal devices only if the owner agrees and (2) use of a personal device without the software agent or its equivalent will only be allowed for read operations on non-critical systems.

Risk profiles are given to subjects and are computed based on their attributes. Risk profiles are dynamic and

continually assessed to determine whether a subject can continue to access a certain PE level.

4.1. Access policy for Zero Trust

Three PE levels shall be assigned according to the criticality of each network zone. PE Level 1 is assigned to network zones with no OT functions. PE Level 2 is assigned to network zones with OT functions. PE Level 3 is assigned to the trusted zone where legacy components, latency sensitive components, and components lacking the computational capacity to support ZT locate.

All subjects shall be assessed and given a risk profile before being granted access to any resource. A subject shall be assigned to one of the following risk profiles after assessment: low risk, medium risk, high risk, or very high risk. For all PE levels, a risk profile for each subject shall be in effect for a period defined by the PE level or until a change in a subject attribute is detected, in which case, the subject shall be reassessed. Table 2 shows the access policy for each PE level. The access reassessment time must be commensurate with the system-specific JITA policy.

4.2. ZT-OT architecture

To implement the ZT-OT architecture, the SWaT design is extended with the addition of PEP, PDP, and PIP components. A PEP is added at the boundary of all network zones. We termed the PEP in the IT network zone as Zone E PEP; the PEP in the OT network zone as Zone C PEP; and the PEP in the trusted zone as Zone B PEP. There are two PDPs: an enterprise PDP and a plant PDP. The rationale for a local PDP is to ensure that each plant is operational even if the link between a water plant and the enterprise network is broken. Access decisions are made based on risk profiles and device telemetry. The PIP is a logical collection of components situated in the enterprise network and provides contextual information pertaining to each subject for use by the PDPs. We assumed that the PDP caches the retrieved attributes for each subject it has encountered for 24 hours, thus making verification involving the subject faster.

Figure 2 shows the ZT-OT architecture with the added PEP, PDP, and PIP. Components shown in black are existing components, components in red are security controls required by the CCOP, components in green are security controls required to secure remote connections, and components in purple are security controls required to secure both remote connections and BYOD user activity. Devices outlined in gold are either newly added security controls for implementing ZT or existing security controls required for implementing ZT.

In ZT-OT, the SCADA server and Historian server were moved from the plant network into the control network due to the addition of the PEP in the control system zone. This change in location is necessary to preserve the ability of the control network to function on its own in the event of an outage of the plant network. By moving the SCADA server and Historian server into the control network, the entire control system's network zone becomes self-reliant in the performance of water treatment operations.

Table 2. Access policy for different PE levels.

PE Level 1 Access Policy	
Whitelisted subjects of low, medium, or high risk shall be allowed to access PE Level 1 network zones.	
The PEP shall reassess the validity of access for all subjects after a configurable time frame. This time frame shall be defined by the enterprise access control policy.	
All read and write requests shall undergo verification by the PEP, and only authorized requests shall be allowed access.	
PE Level 2 Access Policy	
Whitelisted subjects of low and medium risk shall be allowed to access network zones of PE Level 2.	
Only approved devices with software agents shall be allowed to remotely connect to network zones of PE Level 2.	
The PEP shall reassess the validity of access for all subjects after a configurable time frame. This time frame shall be defined by the enterprise access control policy.	
All read and write requests shall undergo verification by the PEP, and only authorized requests shall be allowed access.	
PE Level 3 Access Policy	
Only whitelisted company-furnished equipment of low risk shall be allowed to access network zones of PE Level 3.	
No remote connection shall be permitted.	
No external devices shall be permitted.	
The PEP shall reassess the validity of access for all subjects after a configurable time frame. This time frame shall be defined by the enterprise access control policy.	
All read and write requests shall undergo verification by the PEP, and only authorized requests shall be allowed access.	

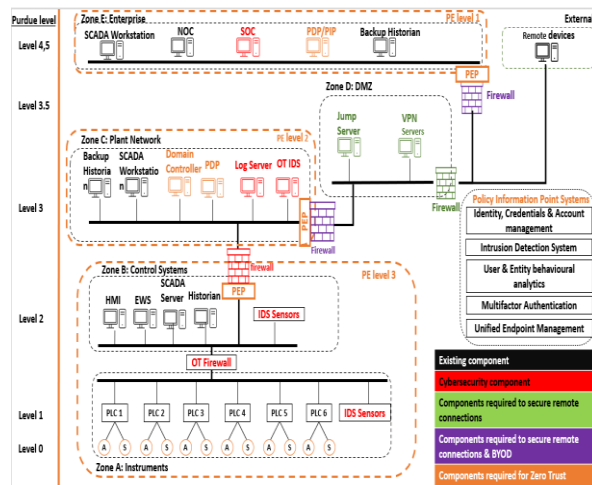


Figure 2. ZT-OT architecture.

4.3. ZT-OT logging

Logging is a CCOP detection requirement (Section 6.1). There are two kinds of logs in ZT-OT: process-related logs and cybersecurity logs. Process-related logs contain log entries associated with events generated by the SCADA systems. They provide historical information on SCADA operation and water parameters. Cybersecurity logs contain log entries for security-relevant events generated by operating systems and application software. These logs record information about various activities and events that are crucial for detecting and investigating security incidents.

In each water plant, process-related logs reside in the Historian in Zone B, while cybersecurity logs are kept in the log collector in Zone C. For the DMZ and enterprise network, there is no process-related log and cybersecurity logs are kept in a log collector in the enterprise network, which is part of the PIP.

Logs maintained by the Historian are also backed up to the Backup Historian in Zone C and Zone E. Incremental backups to the Backup Historian can be set to occur for every change to the Historian or can be scheduled. Full backups of the Historian occur less frequently than incremental backups. Offsite backups of logs are performed and retained in accordance with organizational policies.

The ZTA tenets require constant monitoring and logging of the entire network. In ZT-OT, all logging requests made by devices in different zones (Table 3) are verified by the PEP and PDP within their corresponding zones. Logging request excludes backing up of Historian logs to Backup Historians. Table 3 shows which PEP and PDP are involved in the verification of logging requests.

For Historian backups to the plant Backup Historian in Zone C, the request is verified by the Zone C PEP and plant PDP. Each Historian backup request sent to the enterprise Backup Historian in Zone E is verified by both Zone C and Zone E PEPs and both plant and enterprise PDPs.

5. Analysis of ZT-OT design

We analyzed the ZT-OT design as applied to a hypothetical water treatment system, which is an instantiation of the WTP described in Section 3. Our test system is based on the ZT-OT architecture described in Section 4. Table 4 describes the user roles used in our analysis. Table 5 lists our assumptions. Our use cases are for best-case scenarios and only serve as a proof of concept of our approach. Analyzing scenarios that do not meet our assumption is an area for future work.

A typical WTP has four modes of operation: maintenance, operational, standby, and manual. Our

three use cases only affect the maintenance and operational modes.

Use Case 1: Replace reverse osmosis filter. This use case represents a standard operating procedure during a scheduled period and how ZT-OT affects it. The involved actors are the OT Operator and OT Manager. All actions to change the reverse osmosis filter are performed on CFE within company premises. Figure 3 (Appendix A) provides a graphical representation of the entire sequence of events. Use Case 1 affects Zone A (Instruments), Zone B (Control Systems), and Zone C (Plant Network). See Figure 2. Purdue Levels 0, 1, 2, and 3 are affected.

Table 3. ZT-OT logging requests.

devices	Process-related events	Cybersecurity events
Zone A	Logged in Zone B Historian	Logged in Zone C log collector
	No Zero Trust Verification*	Logging device verified by Zone B PEP & plant PDP
Zone B	Logged in Zone B Historian	Logged in Zone C log Collector
	No Zero Trust Verification*	Logging device verified by Zone B PEP & plant PDP
Zone C	Logged in Zone B Historian	Logged in Zone C log Collector
	Logging device verified by Zone B PEP & Plant PDP	Logging device verified by Zone C PEP & plant PDP
Zone D	No process-related logs.	Logged in Zone E log collector
		Logging device verified by Zone E PEP & plant PDP
Zone E	No process-related logs.	Logged in Zone E log collector
		Logging device verified by Zone E PEP and plant PDP

*No verification: device & Historian are within the trusted zone.

Table 4. User roles used in SUT.

Role	Responsibility
Plant IT Manager	Uses a CFE while on premises and an authorized personal device off-site. Approved for remote access the plant network using the CFE at any time.
OT Manager	Uses a CFE for both on-premises and off-site work. No approved personal device for business use. The CFE used by the OT Manager is approved for remote access to the company network at any time.
OT Operator	Uses CFE while on premises and an authorized personal device remotely. Has approval to remotely access the plant network at any time of day using their CFE and authorized personal device.
Plant Technician	Works closely with the OT Operator to ensure day-to-day operation of the WTP.
External vendor	Always monitored by plant personnel while on premises. When connecting to the WTP OT network remotely, the vendor action will be monitored by an OT Operator.

Use Case 2: Abnormal Water Parameter During Afterhours. Here, abnormal water parameters are

discovered after normal working hours. The involved actors are the OT Operator and OT Manager. Both BYOD and remote connection functionality are required: the OT Operator will operate from home using a personal device after hours and Plant Technicians will be at the WTP premises for physical checks. Figure 4 (Appendix A) shows the event sequence for Use Case 2.

Table 5. Assumptions used in analysis.

Assumptions
The scenarios used for the analysis only cover normal operation, which includes both scheduled and unscheduled operations that are detrimental to WTP operation and can be remedied within a few hours.
The scenarios do not cover emergency cases, i.e., unplanned events that have detrimental effects on WTP operations. Examples are fire, floods, damage to key components such as pumps and turbines, etc.
All user credentials are assumed to be valid.
All device configurations are correctly implemented.
Reactive measures such as incident response or business continuity are out of scope.
The scenarios assume that all ZT components are working as intended and are not targets of any cyber-attacks.
All devices connecting to the company network locally or remotely are either CFE or have CFE agents installed.
All operational processes are assumed to succeed. Failure cases pertaining to ZTA are included in the design analysis.
BYOD devices are solely used for remote access only.

This use case affects Zone A (Instruments), Zone B (Control Systems), Zone C (Plant Network), Zone D (DMZ), and Zone E (Enterprise). This use case affects all Purdue levels from 0 to 5.

Use Case 3: Patch SCADA System. This use case involves granting temporary use of non-CFE and remote access to support a system patch for the OT system by an external vendor during a predetermined maintenance period. The actors are the OT Operator, OT Manager, IT Manager, and external vendor's service engineer. We assume that the vendor has a laptop with a preinstalled WTP-approved software agent for maintenance use. Remote connection functionality is required so that the vendor can assess the system during the pre-patching phase. BYOD procedures are required as the vendor laptop is considered an external non-CFE device.

This use case spans three separate phases: initial enrollment, information gathering day, and patch day. Figure 5 (see Appendix A) shows the entire sequence of events across the three phases. Use Case 3 affects Zone A (Instruments), Zone B (Control Systems), Zone C (Plant Network), Zone D (DMZ), and Zone E (Enterprise). This use case affects all Purdue Levels from 0 to 5.

While these use cases do not address emergency situations, responses to unexpected crises could be

implemented via means of an emergency account. Such accounts should have dual controls of their passwords and the ability to bypass all PEP checks in OT systems. Also, patching in the trusted zone (PE Level 3) can only be performed on-site using CFE equipment.

5.1. Strengths and weaknesses of ZT-OT

Strength 1: Securing remote connection. In Use Case 2 and Use Case 3, ZT provides continual assessment of all systems with remote connections, i.e., the OT Operator, vendor laptop, VPN server, and the Jump Server (Figure 2). Based on the MITRE ATT&CK ICS framework (The MITRE Corporation, n. d.), this helps mitigate the threats from exploitation of remote services and public facing applications. ZT supports granular access control policies, such as access periods and accessible devices or network zones. Our design has three policy enforcement levels to allow risk tolerance to depend on the criticality of the system and network. Proper access control policies and their enforcement is a mitigation method in the MITRE ATT&CK ICS framework (The MITRE Corporation, n. d.) and applies to remote connection threats identified in Section 3.2.

Strength 2: Securing BYOD. ZT supports security assessments of devices, in addition to user authentication. This helps prevent compromised devices from accessing the system, even for authenticated users. The checks are device agnostic and based solely on the device attributes used to enforce the security policy. In ZT-OT, the PE levels serve as a form of network segmentation between the enterprise network, plant network and trusted zone network. Segmentation based on PE levels helps protect critical networks from unauthorized or insecure devices. ZT can also help prevent bridging of networks by using the PEP to block access to the OT system from personal devices that are already connected to an unknown network. Information about unknown connections is obtained from the software agent installed on the personal device. This reflects the MITRE ATT&CK ICS framework (The MITRE Corporation, n. d.) in which network segmentation is a mitigation method for many BYOD threats identified in Section 3.2.

Strength 3: Securing complex OT systems. The proposed ZT architecture makes use of PEP as gatekeepers with PDP and PIP as decision makers. Using this setup, complex OT systems such as transport systems with multiple OT sub-systems can make use of a hub-and-spoke model to fulfill ZT requirements. An advantage of this distributed architecture is to allow correlation among different OT sub-systems such that a potential threat on one will dynamically affect the access policy of another.

Weakness 1: Reliance on software agents and risk of compromised agents. Although optional in our design, a software agent is necessary for a subject to access higher PE levels. Hence, most, if not all, CFE will have a pre-installed agent, and most employees may opt for an agent installed on their personal devices. This creates a dependency on the agent and its integrity. Spoofed agents may result in unauthorized access or may be blocked by malware from communicating with the PEP, resulting in denial of service.

A Trusted Platform Module (TPM) can be used to perform secure operations and protect sensitive information. To reduce the risk of agent tampering, allow agent installation only on TPM-provisioned devices. Also, restrict agent installation to authorized personnel. Furthermore, if only whitelisted devices are permitted to access certain resources, the effects of unauthorized access by a spoofed agent are reduced.

If the device is infected with malware that blocks agent communication, then the only remediation may be to remove the malware or use a new device. In the OT sector, this is dangerous, as it may restrict access to stop the system in an emergency. For example, an emergency stop command to an overheating turbine may be blocked resulting in costly damage to physical environments.

Weakness 2: Compromised trusted zone. In ZT-OT, a trusted zone is created to protect components that cannot support ZT, including latency-sensitive components and legacy systems (Purdue Levels 0, 1, and potentially 2). The trusted zone may also contain physical sensors and actuators with networking capabilities. Due to the criticality of trusted zone devices, we assume PE Level 3 for this zone. Despite the protection offered by ZT-OT, trusted zone compromise is still possible due to human errors or complacency, zero-day exploits, vulnerabilities that create an attack vector into the zone, or direct physical access by a malicious insider. Trusted zone compromise is dangerous as it contains physical instruments that directly affect physical water treatment parameters and can be manipulated. One mitigation strategy is to eliminate the concept of trusted perimeter and apply micro-segmentation to implement ZT on all devices and networks. Further research into the possibility of implementing this interpretation of the ZT paradigm on legacy devices, computational constrained components, and physical instruments is required.

Weakness 3: Single point of failure. In the ZT-OT design, all network traffic must be verified by a PEP, which relies on the PDP and PIP for access decisions. Any of these components is a potential single point of failure, thus jeopardizing the entire network's integrity. A PEP, PDP, or PIP could be the target of denial-of-service attacks, either malicious or accidental. Even actions from legitimate interconnected systems could

contribute to a denial-of-service scenario. For example, a Zone B device might repeatedly attempt to establish a connection or send an error message to the SCADA workstation. This could flood the PEP, impeding its capacity to authenticate requests from other devices. Robust mitigation strategies against denial-of-service threats are needed. One strategy would be to maintain backup PEP, PDP, and PIP to enable timely recovery and reconstitution. In ZT-OT, the complete SCADA system is situated in the trusted zone, which has no ZT components and depends on the ZT components in other zones for protection. Having backup ZT components helps ensure that water treatment operations can continue, even in the event of failure in a ZT component.

Weakness 4: Logging in trusted zone. Logging is a critical aspect of OT systems. Our ZT-OT architecture ensures that logging devices outside of the trusted zone is verified by the appropriate zone-specific PEP and PDP. However, logging of process-related events inside the trusted zone (Zone A and Zone B) has no ZT protection. Mitigation of this threat that meets the trusted zone's strict runtime availability requirements is left as future work.

6. Conclusion

We analyzed the feasibility and effectiveness of deploying the ZT paradigm to OT systems in the water sector. We identified potential threats and, based on NIST's ZT reference architecture, developed an OT

architecture with ZT access control to support both secure remote connections and authorized BYOD. Using a hypothetical water treatment plant, we assessed our ZT-OT design in three use cases: routine maintenance, a non-routine check on water parameters, and scheduled software patches by vendors. We showed both strengths and weaknesses of implementing ZT in OT systems.

We hypothesized that ZT can help modernize and secure legacy OT systems without affecting normal OT operations. Our findings indicate that our ZT-OT design for a legacy water-treatment system can support secure external remote connections and BYOD. Furthermore, the placement of the PEP and PDP components in the ZT-OT design can improve the security of legacy OT systems as they organically segment the OT network. Nevertheless, certain aspects of ZT warrant further investigation. Specifically, the feasibility of applying the ZT model to OT sectors other than water treatment and the use of unexpected devices for emergency handling. Another concern is that ZT mechanisms might inadvertently block SCADA commands, which could adversely impact regular operations.

Disclaimer The views expressed in this material are those of the authors and do not reflect the official policy or position of the Department of Defense or the U.S. Government.

7. Appendix A. Figures

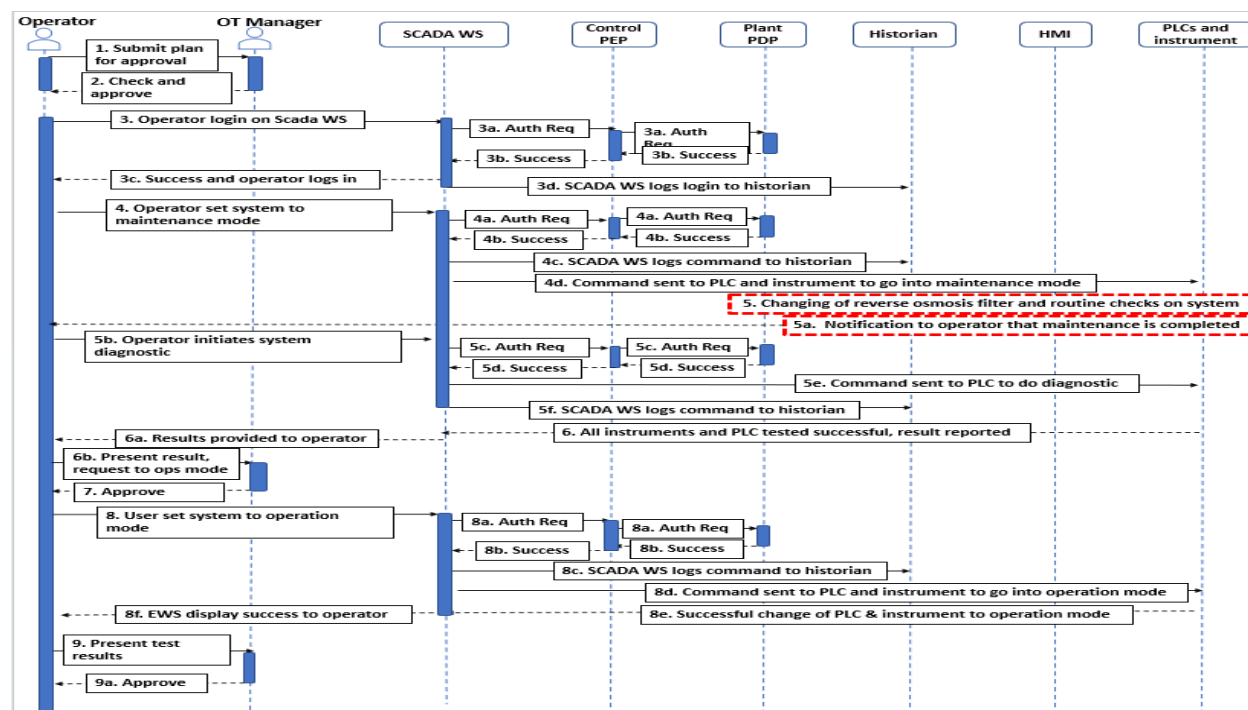


Figure 3. Sequence diagram for Use Case 1.

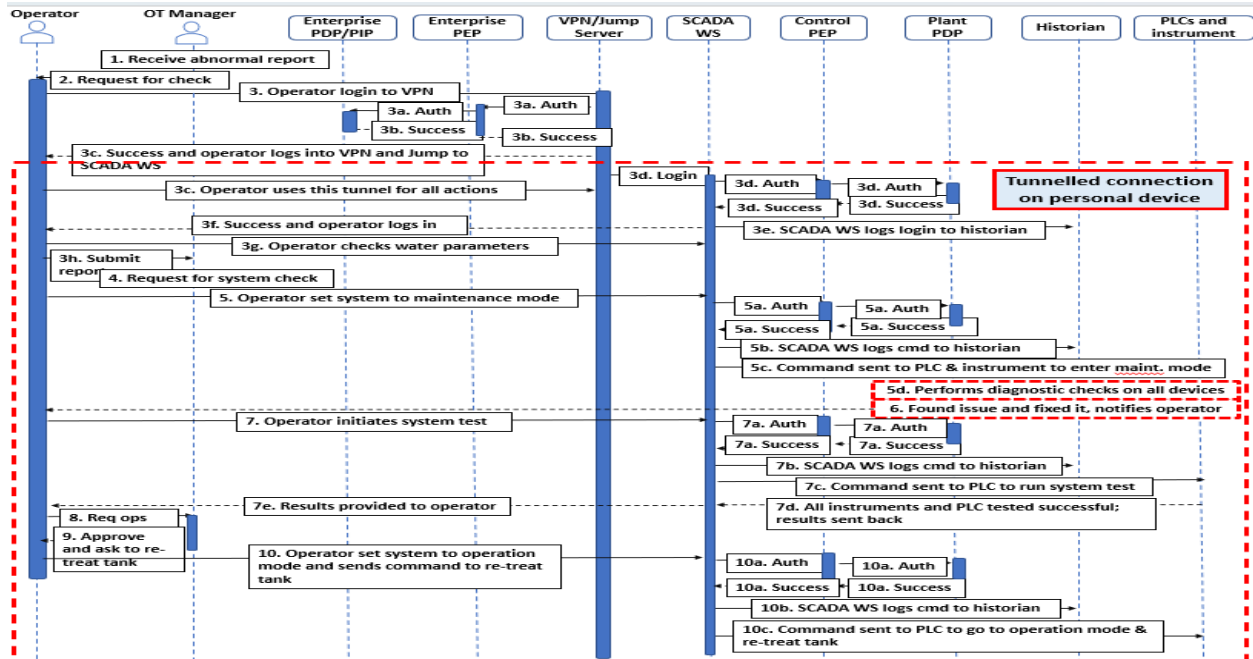


Figure 4. Sequence diagram for Use Case 2.

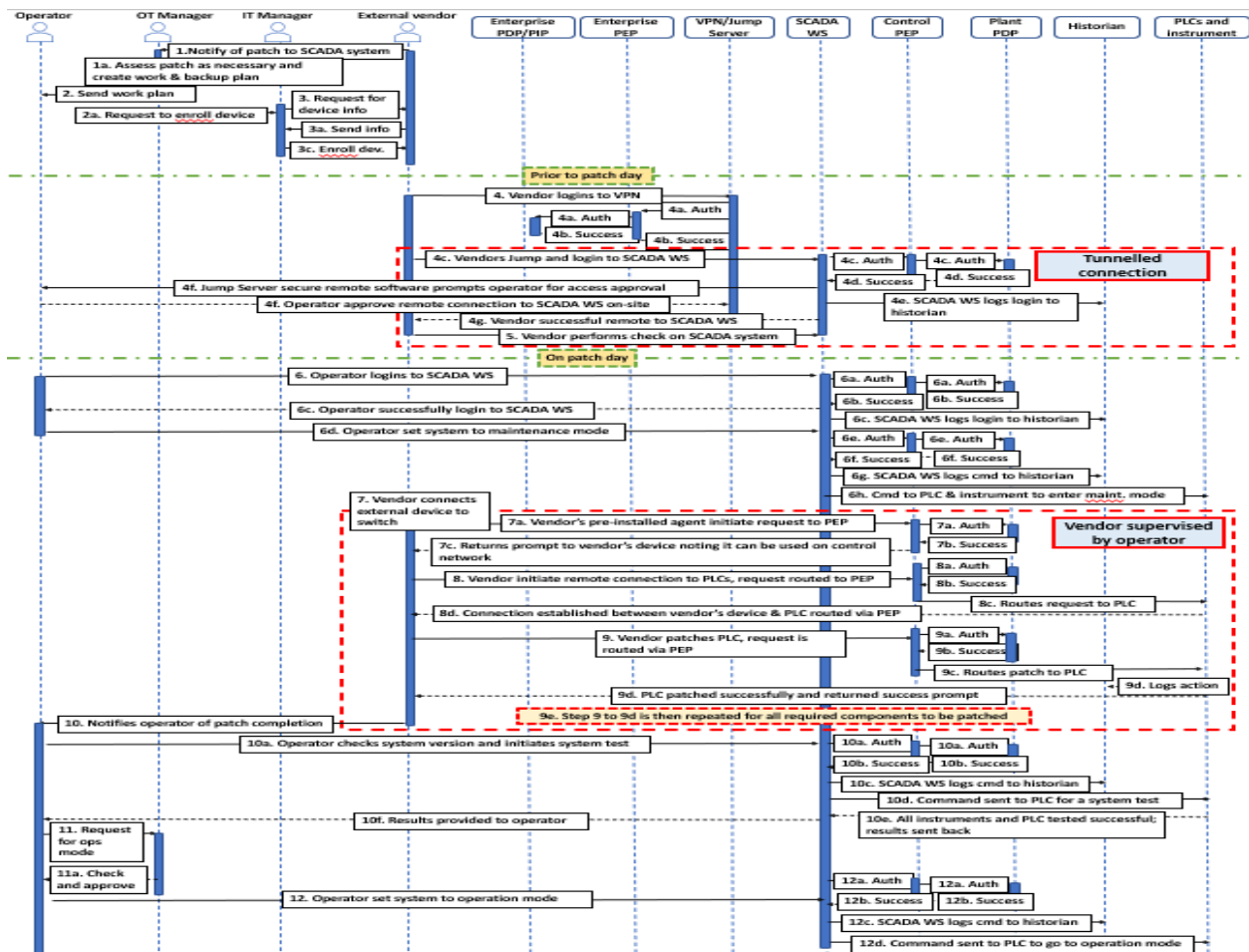


Figure 5. Sequence diagram for Use Case 3

8. References

- Bajak, F. (2023). Microsoft: State-sponsored Chinese hackers could be laying groundwork for disruption, AP News. Accessed: May 21, 2024. <https://apnews.com/article/microsoft-china-hacking-us-infrastructure-d4a4faefcc5d4d3c9f72e9acc24a71f9>
- Basta, N., Ikram, M., Kâafar, M.A., & Walker, A. (2021). Towards a Zero-Trust Micro-segmentation Network Security Strategy: An Evaluation Framework. NOMS 2022-2022 IEEE/IFIP Network Operations and Management Symposium, 1-7.
- Boumhaout, E. B., Danielsen, A. S., Pedersen, O. B. E., & Shahid, M. (2020). Towards Zero Trust for Critical Infrastructure. Massachusetts Institute of Technology. <https://courses.csail.mit.edu/6.857/2020/projects/2-Boumhaout-Danielsen-Pedersen-Shahid.pdf>
- Centre for the Protection of National Infrastructure (2010). Configuring and Managing Remote Access for Industrial Control Systems. Department of Homeland Security. https://www.cisa.gov/sites/default/files/2023-01/RP_Managing_Remote_Access_S508NC.pdf
- Cherepanov, A. (2017). WIN32/INDUSTROYER: A new threat for industrial control systems. ESET. https://web-assets.esetstatic.com/wls/2017/06/Win32_Industroyer.pdf
- Colombo, P., Ferrari, E., & Tümer, E. D. (2021). Access Control Enforcement in IoT: state of the art and open challenges in the Zero Trust era. In 2021 Third IEEE International Conference on Trust, Privacy and Security in Intelligent Systems and Applications (TPS-ISA) (pp. 159-166).
- Cyber Security Agency of Singapore (2022). Cybersecurity Code of Practice for Critical Information Infrastructure. Singapore. <https://www.csa.gov.sg/legislation/Codes-of-Practice>
- Cybersecurity and Infrastructure Security Agency (2021). Compromise of U.S. Water Treatment Facility. Accessed: May 22, 2024. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-042a>
- David, G. (2019). Purdue Model Framework for Industrial Control Systems & Cybersecurity Segmentation. Topic Paper #4-14. National Petroleum Council. https://www.energy.gov/sites/default/files/2022-10/Infra_Topic_Paper_4-14_FINAL.pdf
- Department of Defense (2022). DoD Zero Trust Strategy. <https://dodcio.defense.gov/Portals/0/Documents/Library/DoD-ZTStrategy.pdf>
- Department of Energy (n.d.). Colonial Pipeline Cyber Incident.” Accessed: May 22, 2024. <https://www.energy.gov/ceser/colonial-pipeline-cyber-incident>
- Falliere, N., Murchu, L. O., & Chien E (2011). W32.Stuxnet Dossier. Symantec Corp. https://www.symantec.com/content/en/us/enterprise/media/security_response/whitpapers/w32_stuxnet_dossier.pdf
- Federici, F., Martintoni, D., & Senni, V. (2023). A Zero-Trust Architecture for Remote Access in Industrial IoT Infrastructures. Electronics, vol. 12, no. 3, p. 566. <https://doi.org/10.3390/electronics12030566>
- International Society of Automation (n. d.). ISA99, Industrial Automation & Control Sys Security. ISA standards and Publications. Accessed: May 22, 2024. <https://www.isa.org/standards-and-publications/isa-standards/isa-standards-committees/isa99>
- Levy, M. (2024). States and Congress wrestle with cybersecurity after Iran attacks small town water utilities. Accessed: May 21, 2024. <https://apnews.com/article/water-utilities-hackers-cybersecurity-1c475f5d2ef3b5d52410c93bdeab3aad>
- Miller, K. (2024). Rural Texas towns report cyberattacks that caused one water system to overflow. AP News. Accessed: May 21, 2024, <https://apnews.com/article/texas-muleshoe-water-systems-cyberattacks-russia-5f388bf0d581fc8eb94b1190a7f29c3a>
- National Cyber Security Centre (n. d.). Device Security Guidance for Bring your own device (BYOD).” Accessed: June 4, 2024. <https://www.ncsc.gov.uk/collection/device-security-guidance/bring-your-own-device>
- National Institute of Standards and Technology (2023). Guide to Operational Technology (OT) Security. NIST Special Publication (NIST SP) 800 82 Revision 3. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-82r3.pdf>
- National Institute of Standards and Technology (2022). Implementing a Zero Trust Architecture, Volume B: Approach, Architecture, and Security Characteristics. NIST Special Publication 1800-35B. <https://www.nccoe.nist.gov/sites/default/files/2023-07/zta-nist-sp-1800-35b-preliminary-draft-3.pdf>
- National Institute of Standards and Technology (2020). Zero Trust Architecture. NIST Special Publication 800 207. <https://doi.org/10.6028/NIST.SP.800-207>
- Shore, M., Zeadally, S., & Keshariya, A. (2021). Zero Trust: The What, How, Why, and When. Computer, 54(11), 26-35. <https://doi.org/10.1109/MC.2021.3090018>
- Singapore University of Technology and Design (n.d.). Secure Water Treatment Testbed. Singapore University. Accessed: May 22, 2024. https://itrust.sutd.edu.sg/itrust-labs-home/itrust-labs_swat/
- Slay, J., & Miller, M. (2007, March). Lessons Learned from the Maroochy Water Breach. In International Conference on Critical Infrastructure Protection (pp. 73-82). Boston, MA: Springer US.
- Teerakanok, S., Uehara, T., & Inomata, A. (2021). Migrating to Zero Trust Architecture: Reviews and Challenges. Security and Comm, Networks, vol. 2021, ID 9947347. <https://doi.org/10.1155/2021/9947347>
- The MITRE Corporation (n. d.). ICS Techniques. ATT&CK Matrix for ICS. Accessed: May 22, 2024. <https://attack.mitre.org/techniques/ics/>
- U.S. Senate Republican Policy Committee (2022). Infrastructure Cybersecurity: Water Systems. <https://www.rpc.senate.gov/policy-papers/infrastructure-cybersecurity-water-systems>